Sumon Nath

Offensive Security Engineer | Penetration Testing (VAPT) Lead | Red Team Operator

Bengaluru, India · snath2973@gmail.com · +91 8360207436 · linkedin.com/in/gijutsu-hub · github.com/gijutsu-hub

PROFESSIONAL SUMMARY

Offensive security engineer with 3+ years and 100+ penetration tests delivered across banking and financial services (BFSI), fintech, ecommerce, government and enterprise environments. Microsoft Most Valuable Security Researcher 2022 and 2023, with five assigned Common Vulnerabilities and Exposures (CVE) identifiers and vulnerabilities accepted by Microsoft, Google, Apple and NASA. Runs full lifecycle Vulnerability Assessment and Penetration Testing (VAPT) and MITRE ATT&CK-aligned red team operations against web, Application Programming Interface (API), mobile, thick-client and network targets — and builds the defensive counterpart: secure code review, Static Application Security Testing (SAST) tooling, Continuous Integration/Continuous Deployment (CI/CD) security gates and cloud security posture management on Amazon Web Services (AWS) and Google Cloud Platform (GCP).

KEY ACHIEVEMENTS

- Microsoft Most Valuable Security Researcher (MVR), 2022 and 2023 — awarded for high-impact vulnerability submissions to Microsoft products.
- Five CVE identifiers assigned through coordinated vendor disclosure, plus a contribution to a MITRE Common Weakness Enumeration (CWE) entry.
- Vulnerabilities accepted by Microsoft, Google, Apple and NASA across 100+ public and private bug bounty programs.
- First-author peer-reviewed book chapter published by Springer Nature (879 accesses as of November 2026).

WORK EXPERIENCE

Senior Security Researcher, Team Lead

Alphawave Technology Pvt Ltd (Mitigata Security) | Bengaluru, India

Jan 2026 - Present

- Delivered penetration testing across 100+ enterprise clients covering web, REST/GraphQL/SOAP APIs, mobile (iOS and Android), internal and external network, Active Directory and perimeter firewall scope, holding sole technical sign-off on every report released.
- Cut time-to-first-finding on every engagement by engineering a reconnaissance and attack-surface automation pipeline (Amass, httpx, nuclei) that performs continuous asset enumeration and vulnerability chaining in place of manual discovery.
- Executed MITRE ATT&CK-aligned adversary emulation end to end: stood up command-and-control (C2) infrastructure with redirectors and domain fronting, defeated antivirus and Endpoint Detection and Response (EDR) through AMSI/ETW patching and reflective loading, then chained Kerberos abuse, credential harvesting and lateral movement to controlled exfiltration.
- Restored testing coverage against EDR-protected estates by writing custom offensive tooling, payloads and loaders in Python, C and Go where signatured commercial tooling was blocked.
- Produced audit-grade deliverables accepted directly by regulated BFSI and fintech clients by mapping every finding to Common Vulnerability Scoring System (CVSS) 3.1 vectors, CWE classes and SEBI CSCRF, CERT-In and ISO 27001 controls.
- Extended assessment scope into cloud by running Cloud Security Posture Management (CSPM) across AWS and GCP — Identity and Access Management (IAM) privilege-escalation path analysis, storage exposure review and CIS Benchmark assessment — alongside Software Bill of Materials (SBOM) generation and Software Composition Analysis (SCA) for supply-chain risk.
- Led and mentored a team of security interns while owning report quality assurance, document control and the delivery pipeline end to end.

Senior Software Engineer and Security Researcher

Loginsoft Pvt Ltd | Hyderabad, India

May 2024 - Nov 2025

- Gave detection engineering a reproducible ground truth by reverse-engineering disclosed CVEs into working proof-of-concept exploits and shipping them as deterministic test cases in instrumented sandbox environments.
- Reduced false positives in SAST and SCA tooling (Checkmarx, Snyk) by authoring custom query rules with purpose-built sink and source definitions, widening true-positive detection coverage at the same time.
- Shifted security left across engineering teams by embedding automated scanning, dependency auditing and policy enforcement gates directly into CI/CD pipelines.
- Performed threat modeling, root-cause security debugging and vulnerability research across enterprise application stacks, aligned to CIS Benchmarks for server hardening.

Security Intern

Centre of Excellence in Cyber Security, VIT Bhopal | Bhopal, India

Jan 2023 - Feb 2024

- Designed and operated 20+ Capture The Flag (CTF) events in Jeopardy and Attack-Defense formats for 1,000+ participants, authoring challenges in web exploitation, binary exploitation, reverse engineering, cryptography and forensics, sponsored by Offensive Security, Bugcrowd and HackerOne.
- Hardened campus infrastructure through firewall rule design, network segmentation using VLANs and access control lists, and deployment of enterprise security appliances.
- Supported vulnerability assessments and research on network security protocols and defensive architecture.

TECHNICAL SKILLS

Penetration Testing and Red Teaming
Vulnerability Assessment and Penetration Testing (VAPT), Web Application Penetration Testing, API Security Testing (REST, GraphQL, SOAP), Mobile Application Penetration Testing (iOS, Android), Network Penetration Testing, Internal and External Infrastructure Testing, Active Directory Security, Kerberos Attacks, Red Team Operations, Adversary Emulation, Command and Control (C2) Infrastructure, Initial Access, Privilege Escalation, Lateral Movement, EDR and Antivirus Evasion, Thick Client Testing, Wireless Security, Firewall and Perimeter Assessment

Vulnerability Research and Reverse Engineering
Vulnerability Research, Reverse Engineering, Binary Exploitation, Exploit Development, CVE Research and Reproduction, Proof of Concept (PoC) Development, Coordinated Vulnerability Disclosure, Bug Bounty Hunting, Offensive Tooling Development, Cryptography, Digital Forensics

Application and Cloud Security
Secure Code Review, Static Application Security Testing (SAST), Dynamic Application Security Testing (DAST), Software Composition Analysis (SCA), Software Bill of Materials (SBOM), Supply Chain Security, Threat Modeling (STRIDE), Secure Software Development Lifecycle (SDLC), DevSecOps and CI/CD Security, Cloud Security Posture Management (CSPM), Amazon Web Services (AWS), Google Cloud Platform (GCP), Identity and Access Management (IAM) Security, Container Security

Detection and Response
Security Operations Centre (SOC), Endpoint Detection and Response (EDR), Detection Engineering, MITRE ATT&CK Mapping, Threat Intelligence, Incident Response, Log Analysis, Purple Teaming

Security Engineering and Automation
Security Automation, Attack Surface Management, Reconnaissance Pipelines, Machine Learning for Security, Large Language Model (LLM) Integration, Full-Stack Development, REST API Design, Linux System Hardening, Technical Report Writing, Team Leadership and Mentoring

Frameworks and Standards
MITRE ATT&CK, OWASP Top 10, OWASP Application Security Verification Standard (ASVS), OWASP API Security Top 10, OWASP Mobile Top 10, Common Vulnerability Scoring System (CVSS) 3.1, Common Weakness Enumeration (CWE), NIST Cybersecurity Framework, NIST SP 800-115, Penetration Testing Execution Standard (PTES), ISO 27001, SEBI CSCRF, CERT-In, CIS Benchmarks

Offensive Security Tooling
Burp Suite, Nmap, Metasploit, Cobalt Strike, BloodHound, Impacket, nuclei, ffuf, sqlmap, Amass, subfinder, httpx, CrackMapExec, Rubeus, Mimikatz, Hashcat, Sliver, MobSF, Frida, jadx, Ghidra, Wireshark, Nessus

Security Engineering and Analysis Tooling
Checkmarx, Snyk, Semgrep, Trivy, Syft, Grype, ScoutSuite, Prowler, Pacu, Sophos EDR, Docker, Git, GitHub Actions, PyTorch

Programming and Scripting
Python, C, C++, Go, Rust, PowerShell, Bash, JavaScript, TypeScript, SQL, Solidity, Node.js, React

KEY PROJECTS

CtrlSec - AI-Powered Autonomous Security Operations Platform
`ctrlsec.io`

- Architected and built a full-stack autonomous threat-detection platform single-handedly — backend services, Large Language Model (LLM) inference pipeline, threat-logic layer, compliance engine and frontend console — across Python, Go, Node.js, React and Next.js.
- Unified real-time threat-intelligence ingestion, automated alert triage and correlation, and adversarial-simulation workflows into one security operations centre (SOC) console.

AI-SAST Scanner - Deep-Learning Vulnerability Detection

- Built a deep-learning static analysis engine in PyTorch (Convolutional Neural Network with Bidirectional Long Short-Term Memory and Transformer attention) performing cross-function taint analysis over 35 vulnerability classes across 9 programming languages.
- Trained it on a synthetic corpus of 887,000 labeled entries generated by an LLM-based supervision and validation framework, benchmarked against the OWASP Benchmark.

PUBLICATIONS

- Nath, S., Azath, H., Patel, S. C., Al-Safarini, M. Y., Lamkuche, H. S., Irziqat, S. (2025). Blockchain-Based Knowledge Repository for Training Artificial Intelligence Models: Bridging AIML with Decentralized Data. Studies in Systems, Decision and Control, vol. 587, pp. 1723–1733. Springer Nature Switzerland. DOI: 10.1007/978-3-031-87584-7_126

CERTIFICATIONS

- Certified Ethical Hacker (CEH) - EC-Council
- Offensive Security Certified Professional (OSCP) - In Progress

SPEAKING AND COMMUNITY

- Organiser and challenge author for Damncon 2021 and 2022, a 24-hour Capture The Flag event rated 17.54 on CTFtime; challenge contributor to cyhunt and BSides.
- Invited speaker at security events for research contributions, including by Microsoft.

EDUCATION

Integrated Master of Technology (M.Tech), Computer Science and Engineering
Specialisation in Cybersecurity
`Vellore Institute of Technology (VIT), Bhopal, India | 2020 - 2025`